WEEK 5 VERIFICATION REPORT

Integrated privacy controls, security tests, and Phi latency confirmation

Led and completed by Yuktha Naveen | Privacy and Security Lead | 5 Sep 2026

Outcome: I verified the merged local SLM path across privacy, security, safety, dependencies, and integration. The evidence supports conditional approval for synthetic local development only.

10 / 10	276 / 276	2.57 s
FOCUSED PRIVACY TESTS	FULL PYTEST SUITE	MEAN LOCAL LATENCY

Yuktha Naveen Week 5 assurance contribution

- I converted the Week 4 privacy principles into a post-merge assurance gate for network calls, telemetry, logs, dependencies, and data minimisation.
- I ran privacy, transport, safety, dependency, frontend, and full integration checks against merged main and investigated the results.
- I remediated the local dependency-tool finding and confirmed Phi-4 Mini latency with the same five synthetic prompts on my Mac.

How to read the evidence

Evidence class	What is supported	Status
Implemented	The merged client and safety boundary exist in source.	Complete
Automated	Privacy, transport, safety, dependency, frontend, and integration checks ran.	Verified
Measured	A repeat local Phi benchmark and real synthetic smoke run completed.	Measured
Participant use	Whole-device disconnected testing and governance controls remain open.	Pending

1. Implemented privacy architecture

Merged implementation, not only a design target. The evidence contract, deterministic safety routing, loopback client, local model, and output-grounding gate now form an executable local path.

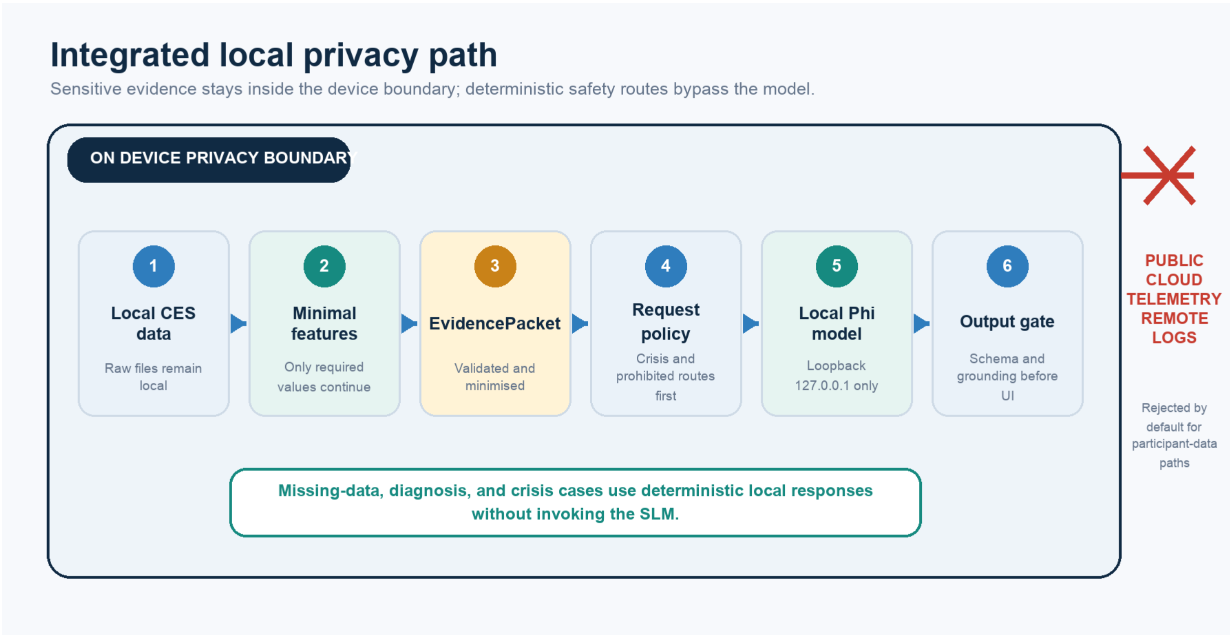

Figure 1. Merged on-device participant-data path and public-network boundary.

Implemented controls

- **Network:** the application client accepts only loopback HTTP /api/chat endpoints and rejects public hosts.
- **Transport:** environment proxies are disabled and HTTP redirects are refused before a second request can occur.
- **Data minimisation:** participant_ref is replaced with redacted; callers must still minimise free text and other IDs.
- **Safety:** missing-data, diagnosis, prohibited, and crisis routes can return deterministic local responses without invoking the model.

Assurance boundary: The tests cover Python and application transport paths. They do not replace a whole-device Wi-Fi-off test, packet capture, or governance approval for participant use.

2. Network calls, telemetry, and logs

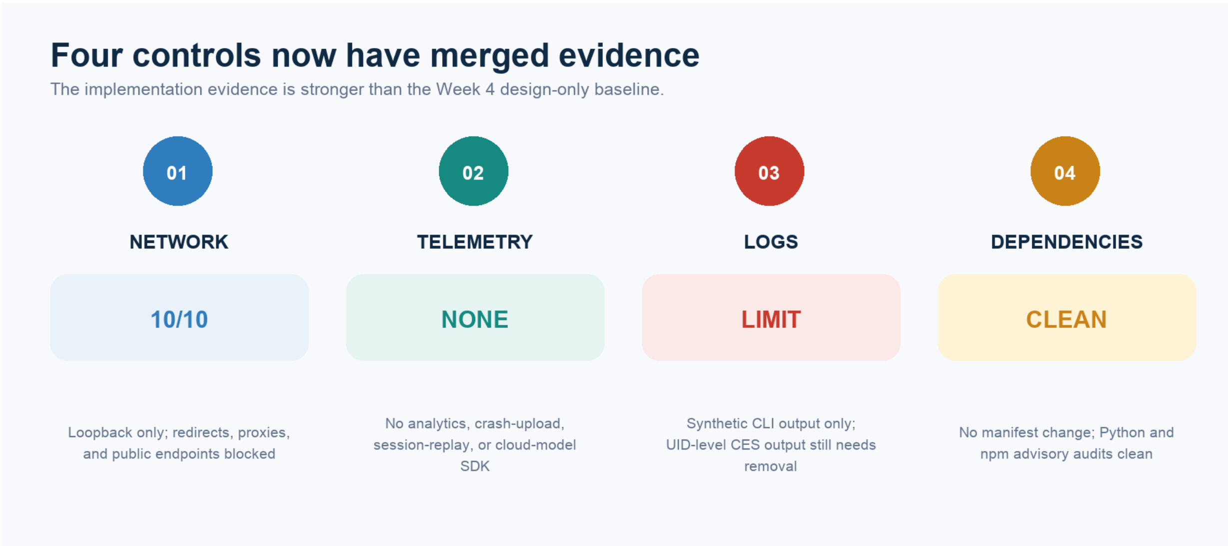

Figure 2. Current repository evidence for the four privacy control areas.

Network decision rule

Category	Decision
Allowed by default	Loopback calls between local components using pre-installed runtime and models.
Privacy review required	Any public endpoint, cloud model, remote asset, telemetry SDK, updater, or install-time download.
Blocked by default	Public calls from participant-data processing, inference, logging, or safety paths.

Logging boundary

Allowed technical evidence	Sensitive content that must not be logged
Aggregate latency, pinned model tag, component events, non-identifying errors, privacy-safe counts	Raw sensors, participant IDs, linked prompts/responses, PHQ-4 values, crisis text, secrets, identifying paths

Repository findings checked on 5 Sep 2026

- No telemetry, analytics, crash-upload, session-replay, cloud-model SDK, or automatic frontend request was detected.
- The six Vite starter links remain user-clicked public links and must be removed or explicitly approved before participant use.
- Ollama and its model server were observed listening only on 127.0.0.1; no established external Ollama connection appeared in the snapshot.
- The CES eligibility CLI can still print UID-level details; shared logs and screenshots must use aggregate reason counts.

3. Dependency and security review

No Python or npm manifest changed in the merged Week 5 delta. The standing PR rule remains required, and current advisory checks were rerun after merge.

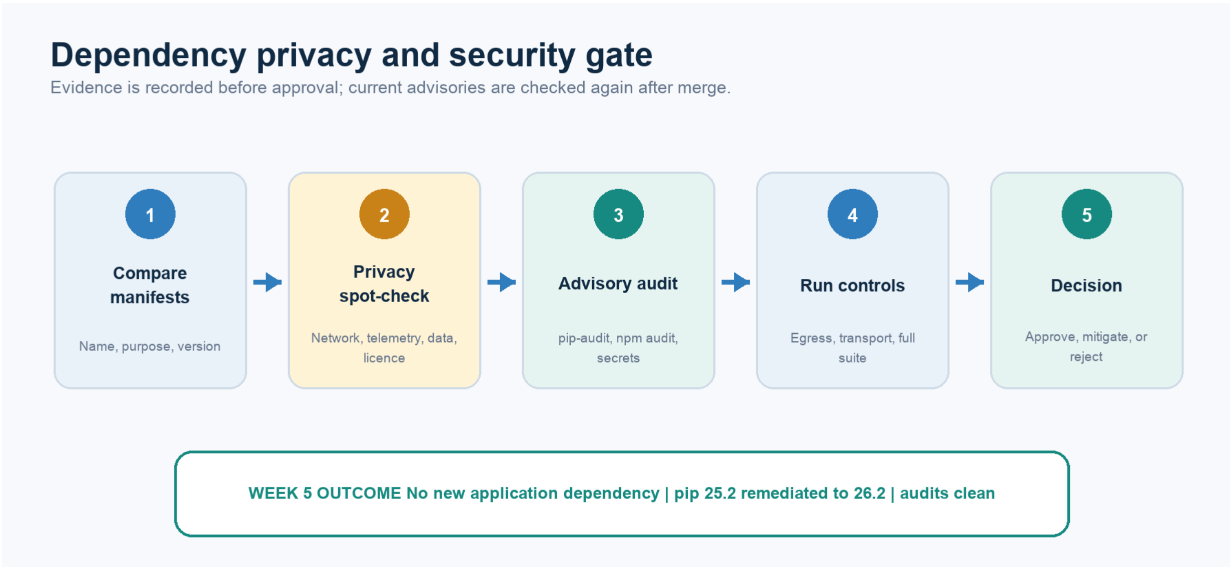

Figure 3. Dependency evidence moves from proposal to post-merge verification.

Checks completed

- Compared requirements.txt, package.json, package-lock.json, and development tooling declarations.
- Checked default network calls, telemetry, crash reporting, diagnostics, and usage metrics.
- Checked install scripts, post-install downloads, auto-updates, and remote model or binary downloads.
- Checked access to participant data, questions, model responses, wellbeing labels, and derived features.
- Ran pip check, installed-environment pip-audit, npm audit, and tracked secret-pattern scans.
- Confirmed standard-library urllib remains the transport; no new HTTP SDK was added.

Remediated finding: pip 25.2 in the untracked local virtual environment had current advisories. It was upgraded to 26.2 and the repeated audit was clean. Python application requirements remain mostly unpinned and still need a resolved lockfile.

4. Confirmed SLM latency benchmark

Phi-4 Mini was rerun through the local Ollama API using the same five synthetic prompts as Week 4. All five requests completed and no participant data was used.

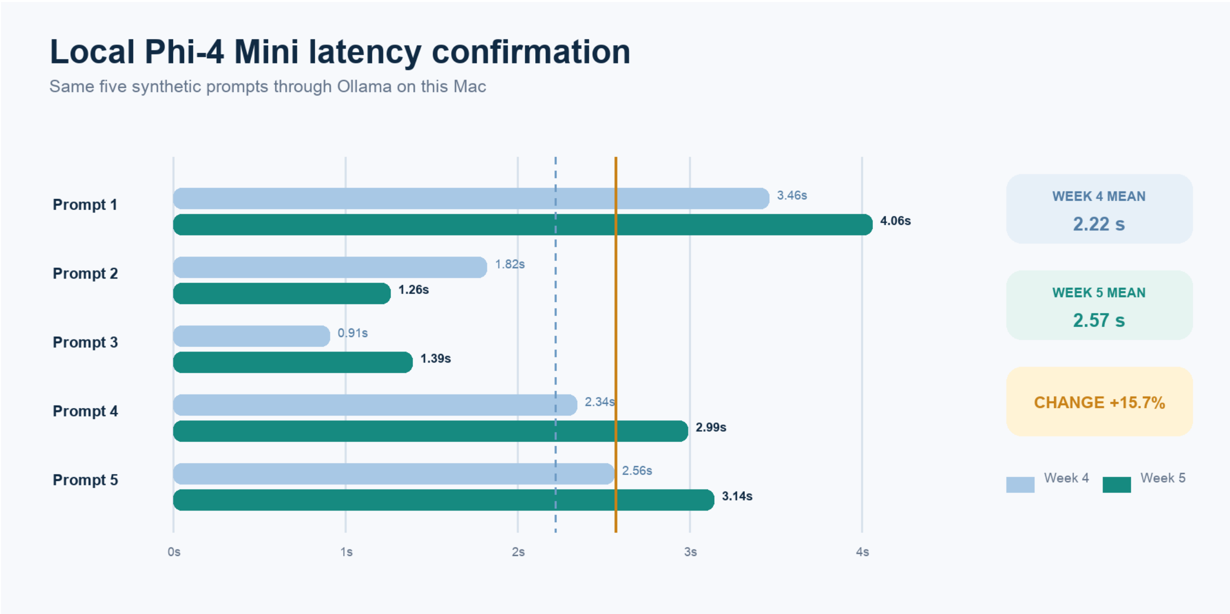

Figure 4. Week 4 and Week 5 real-machine latency for the same five prompts.

Benchmark field	Recorded result
Provider and model	Ollama / phi4-mini:3.8b baseline candidate
Endpoint	http://127.0.0.1:11434/api/generate
Machine	Apple arm64 Mac; Python 3.14.0; run 5 Sep 2026 12:56 AEST
Runs	5 synthetic prompts; 5 successful responses
Latency	min 1.26s | mean 2.57s | median 2.99s | sample p95 3.88s | max 4.06s

Correct interpretation

- Mean latency increased by 0.35 seconds, or 15.7%, from Week 4; the local model still runs at prototype scale on this Mac.
- Five runs are a small sample, and the p95 is an interpolated sample statistic rather than a production tail-latency estimate.
- The raw speed harness bypasses the integrated request and output gates, so its generated wording is not approved product output.
- Phi remains the baseline and Qwen3 the challenger; the repository records final model selection as comparison_pending.

5. Evidence, decision, and follow-ups

Evidence class	What is supported	Status
Merged privacy path	Loopback transport, proxy/redirect blocking, redaction, and safety routing exist.	Verified
Automated checks	10 focused and 276 total tests passed; lint/build checks passed.	Passed
Dependency security	Python and npm audits are clean after local pip remediation.	Passed
Participant deployment	Disconnected app test, logging design, broader minimisation, and governance remain open.	Pending

What is known

- Privacy and transport checks passed 10/10; the complete merged repository passed 276/276 tests.
- Real Phi smoke passed 4/4; the prohibited-request baseline passed 16/16 with zero unexpected model calls.
- Dependency audits are clean after the pip upgrade; latency mean is 2.57 seconds and sample p95 is 3.88 seconds.

Required before participant-facing use

- Run the integrated app with public networking blocked and record process-scoped evidence.
- Remove or approve external starter links; replace UID-level CES output with aggregate counts.
- Define real-user logging, retention, redaction, and broader input-minimisation controls.
- Create a Python lockfile and complete joint, held-out, and governance review.

Repository evidence and references

Report: privacy/week5_privacy_security_report.md | Client: backend/slm/client.py | Tests: tests/privacy/test_no_network_egress.py and tests/slm/test_transport_privacy.py | Benchmark: benchmarks/slm_latency_results.json | References: Ollama FAQ, Python urllib documentation, and OWASP Logging Cheat Sheet.

Short explanation for the team

Team summary: As Privacy and Security Lead, I turned the local-first design into a tested release gate. I verified the merged SLM boundary, completed dependency and security checks, remediated the local pip finding, and confirmed Phi-4 Mini latency. The result is evidence-backed conditional approval for synthetic development, while participant-use safeguards remain open.